

Block 11d: refuse writes to incompatible future storage

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Immediate target: fork audit/715-11c-build-review-repairs-20260928 at 659580c7cf91483c066f6ad4561290cb17b7e257 (PR #882). Code commit: 08eaa257c6730dfe0310c6a5ca89d83bf436410f. Final containing head and hosted CI belong in the PR body. Master template SHA256 at intake: 985cd8f5708e20ac34bf7442454b7ddb2271f5e9a2de048006dd75fb6f4c5556.

1. Scope and source reconciliation

This unit guards persistent operations when firmware encounters an on-flash storage format newer than it understands. The detected state intentionally looks uninitialized after boot while writes are suppressed, so seed creation or settings commands could otherwise claim success without surviving restart. The common CHECK_STORAGE_WRITABLE guard rejects both newer-format and Bitcoin-only incompatible storage before setup, confirmation or mutation. It covers creation starts (continuations such as EntropyAck and CharacterAck are then refused as out-of-sequence, since no ceremony can be armed), PIN and wipe-code changes, settings and policies, plus authenticator commands carried by Ping because authenticator reads may re-encrypt and persist data. Read-only Ping and Initialize remain available. The explicit WipeDevice path remains usable so the owner can erase the incompatible wallet. storage_commit() preserves the lock until explicit wipe.

No protocol definitions or dependency pins change. The tests use a real scratch flash image and exercise both the newer normal-band version and Bitcoin-only format. They check flash and RAM state remains untouched on refused commands, that no confirmation is requested, that ordinary read-only requests work, cancellation preserves the lock, and confirmed wipe permits later load/settings and reset/recovery flows.

2. Verification

Local full and Bitcoin-only emulator suites passed. The full firmware suite ran 699 tests; 30 focused incompatible-storage cases passed. Bitcoin-only ran 167 firmware tests; 24 focused incompatible-storage cases passed. Both reported zero failures, errors or skips. Full/BTC native firmware XML and logs plus focused case XML and logs are preserved in 715-11d-controls-20260928.tgz.

Local check	Full	Bitcoin-only	Outcome
Firmware native	699	167	All pass, zero failures/errors/skips
Incompatible-storage cases	30	24	All pass
Write refusal	Newer normal-band and Bitcoin-only formats	Same	No staging, flash mutation or confirmation
Explicit confirmed wipe	Both formats	Both formats	Subsequent load/settings and setup paths work

Archive SHA256: 07c455d675dc8115367bd4241893aa4a166a65737b32da0d60dba57de274f292. Its manifest binds eight raw test XML/log members and hashes. These local results qualify the initial guard implementation. Review-driven changes to Bitcoin-only status and recovery messaging were

validated on the final hosted candidate below. Physical-device behavior is not claimed.

Final hosted candidate qualification

Final source: b5d9e8b4b112e6b62b3c62d83a41a22cc12baf6d; immediate predecessor: 659580c7cf91483c066f6ad4561290cb17b7e257. Manual workflow-dispatch run [36509637059](https://github.com/BitHighlander/keepkey-firmware/actions/runs/36509637059) completed successfully at this exact source. Required format, secret scan, submodule and release evidence gates; static analysis; full and Bitcoin-only emulator builds, native tests, Python integrations, dylib tests, ARM builds and report generation all passed. Emulator publishing was intentionally skipped.

The hosted report binds Python source aae89d378d889b3872696469fe363cf570e5ac4c, run metadata, PDF SHA256 ffe6f5ad7d53fcdd0d16a4d67fab61d96526718f4bb82ec317c57c04d63daa73, and merged JUnit SHA256 be2168899e1965871f328e4cce74bfa0e75739d6a0092cc6c55f8863952343d. Aggregate: 1,551 passed, 84 declared skips, zero failures or errors. Full and Bitcoin-only native firmware suites passed 699 and 167 tests, including all 30 and 24 incompatible-storage cases. Each ARM variant has 23 files; artifact manifests, firmware hashes and Python pin match the candidate.

Copilot round 1 found (1) misleading destructive recovery guidance for a newer Bitcoin-only format and (2) missing - markers for binary inventory files. The status is now distinct from a foreign Bitcoin-only wallet, and upgrade guidance is shown on write and load/reset paths. The binary markers are present in the inventory. Two follow-up CI runs exposed stale variant-specific assertions, corrected in commits e81254ae99f4dbe66d5885484a2bc45d2d972917 and b5d9e8b4b112e6b62b3c62d83a41a22cc12baf6d; the final run above is green. The evidence-refresh head 0c08ce9ef4869269922c4c0b62f7ac069d7c81ea then passed manual run [36511361026](https://github.com/BitHighlander/keepkey-firmware/actions/runs/36511361026) with identical native case identities, 1,551 passed, 84 declared skips and zero failures; PDF SHA256 09e4e4c6dd51b19dee346d1ca5340a90f1146a6deb93d04e4a09ff1af34f2527.

Copilot round 2 (review 5347145662 on 0c08ce9ef) required code changes. (1) Its overview found the three compatibility locks cleared only by `storage_wipe()`, so a reinitialized emulator loading a valid image after an incompatible one kept refusing writes; `storage_init()` now clears them before classifying. Devices were unaffected because the statics reset at boot. (2) Refusal tests asserted only the failure type; they now assert the exact guidance per image and build, and that a too-new Bitcoin-only wallet is never told to wipe. (3) The lock documentation names both classification paths. Repair commit 1503b35d5, with new test `ReinitializingOnFreshFlashClearsIncompatibleLocks`. Its first hosted run, [36514935877](https://github.com/BitHighlander/keepkey-firmware/actions/runs/36514935877), showed the new message assertions were wrong for the two continuations. They are refused as out-of-sequence ("Not in Reset mode" / "Not in Recovery mode"), not by the storage guard; the test now asserts that. The firmware was unchanged and every other message assertion passed. Hosted CI at the repair head, a negative control, and Copilot round 3 are recorded in the PR.

3. Adjacent inventory

Inventory base: 659580c7cf91483c066f6ad4561290cb17b7e257. Reproduce with `git diff --numstat BASE..FINAL_PR_HEAD` after the report, PDF and controls archive are committed.

Added	Deleted	Path
4	2	include/keepkey/firmware/storage.h
44	28	lib/firmware/fsm.c
6	4	lib/firmware/fsm_msg_common.h
22	4	lib/firmware/storage.c

Added	Deleted	Path
2	0	lib/firmware/storage.h
335	1	unittests/firmware/fsm.cpp
2	2	unittests/firmware/storage.cpp
49	0	docs/release/audit-units/715-11d-future-storage-guards-20260928.md
-	-	docs/release/audit-units/715-11d-future-storage-guards-20260928.pdf
-	-	docs/release/audit-units/715-11d-controls-20260928.tgz